

Overview

Multi-stage layered Dockerfile, full docker-compose with 15+ services, non-root user, read-only rootfs, secrets via env injection, and Snyk CVE scanning in CI.

Multi-Stage Dockerfile

Stage 1: builder (FROM maven:3.9-eclipse-temurin-21)

COPY pom.xml → mvn dependency:go-offline (cached layer)

COPY src → mvn -B package -DskipTests

Stage 2: runtime (FROM eclipse-temurin:21-jre-jammy)

addgroup shopverse + adduser shopverse (non-root)

COPY --from=builder app.jar

EXPOSE 8080

ENTRYPOINT ["java","-XX:+UseG1GC","-jar","app.jar"]

Docker Compose Services

Service	Image	Purpose
postgres-primary / replication	postgres:16	Source-of-truth DB + streaming replication
redis	redis:7	Cache, sessions, rate limiting, pub/sub
mongodb	mongo:7	Product documents, reviews
cassandra	cassandra:4	OrderEventLog
neo4j	neo4j:5	Product recommendations graph
elasticsearch	elasticsearch:8	Full-text search index
kafka (KRaft)	confluentinc/cp-kafka	Event streaming (no ZooKeeper)
keycloak	keycloak:23	OAuth2 / OIDC provider
prometheus + grafana	prom/prometheus, grafana	Metrics & dashboards
zipkin	openzipkin/zipkin	Distributed tracing
nginx	nginx:1.25	Reverse proxy, TLS, rate limiting

Compose File Strategy

File	Profile	Contents
docker-compose.yml	All	Core services with named volumes

File	Profile	Contents
docker-compose.override.yml	Dev	spring-boot-devtools, debug port 5005, no TLS
docker-compose.prod.yml	Prod	mem_limit: 2g, restart: unless-stopped, no dev overrides
docker-compose.monitoring.yml	Standalone	Prometheus + Grafana + Loki (no K8s needed)

Security Hardening

- Non-root user: addgroup/adduser shopverse.
- read_only: true on app container; tmpfs for /tmp.
- No secrets in ENV; use Docker secrets or CI env injection.
- docker scan (Snyk) step in CI fails build on HIGH/CRITICAL CVEs.
- .dockerignore excludes target/, *.md, .git, load-tests/.